Testcase Management — Security Testing Report — 2026-10-21

Client-reported REST API issue verification: a genuine API client getting a false CSRF rejection.

Test Case Execution

TC ID | Result
TC-TCM-278 | PASS

Summary: 1 executed — 1 Pass / 0 Fail / 0 Blocked / 0 Skipped

Bugs / Defects Found

None — the client-reported issue was already fixed on the dev-provided build; no new bug filed.

Notes / Findings

- Client (lnastev) reported that a genuine REST API client (HTTP Basic auth, API key as username — a documented
Redmine REST API auth method) got a false 422 {"error":"Invalid form authenticity token."} on
POST test_suites.json, with the server log showing Filter chain halted as :rftc_verify_session_csrf!.
- Root cause (per the code's own comment in app/controllers/concerns/rftc_access_control.rb, written in
response to this exact customer report): the SEC-004 hardening added a filter pair
(restore_session_user_for_api + rftc_verify_session_csrf!) that an earlier version couldn't use to
distinguish a real API client from a cookie-authenticated browser session, wrongly CSRF-blocking the former.
- Confirmed already fixed on the dev-provided C:\crux-redmine build — the fix gates the CSRF check behind a
@rftc_session_cookie_authenticated flag only set when the user was actually resolved from the session cookie,
never for a real API-key-authenticated request.
- Live-verified the client's exact method (HTTP Basic, key as username) and the ?key= URL-param variant on
test_suites.json — both return 201 Created, no CSRF rejection, server log shows Current user: admin.
- Per explicit follow-up request, extended verification to every other endpoint in the plugin using the same
rftc_verify_session_csrf! filter, not just test_suites.json: RequirementsController#create,
RunsController#create, IssueStatusResultsController (#create/#bulk_create/#link_defect/
#unlink_defect), RequirementIssuesController (#create/#destroy), and
Apis::CiTestRunController#bootstrap_run. Zero CSRF rejections anywhere — every request resolved
Current user: admin. RunsController and IssueStatusResultsController each carry their own locally
duplicated copy of restore_session_user_for_api (per that file's own comment) — both read in full and
confirmed matching the fixed guard logic, so the fix is consistently applied everywhere, not just the shared
concern.
- One unrelated, minor, not-filed observation: IssueStatusResultsController#create 500s on a flat (non-nested)
request body instead of a clean 422 — same class as BUG-TCM-040/043, noted for a future input-validation pass,
out of scope for this CSRF check.
- No production ticket existed for this specific customer report, so no bug was filed or closed — this report
documents the verification only.
- Redmine Version: 6.x (Docker)
- Environment: Docker localhost:3015 (C:\crux-redmine), project test
- Test Date: 2026-10-21